AP2 框架及相关衍生问题研究

基于 node 与 transpath 的分层安全分析

Anonymous Authors

2026 年 10 月 – 2027 年 2 月

01 总体框架

本文研究 AP2 交易系统中，参与节点（**node**）与有向传输路径（**transpath**）在不同对手能力和观察条件下形成的安全风险。分析依次确定系统边界、对象范围、对手能力与可见信息，再按受损的安全属性归类攻击机制。

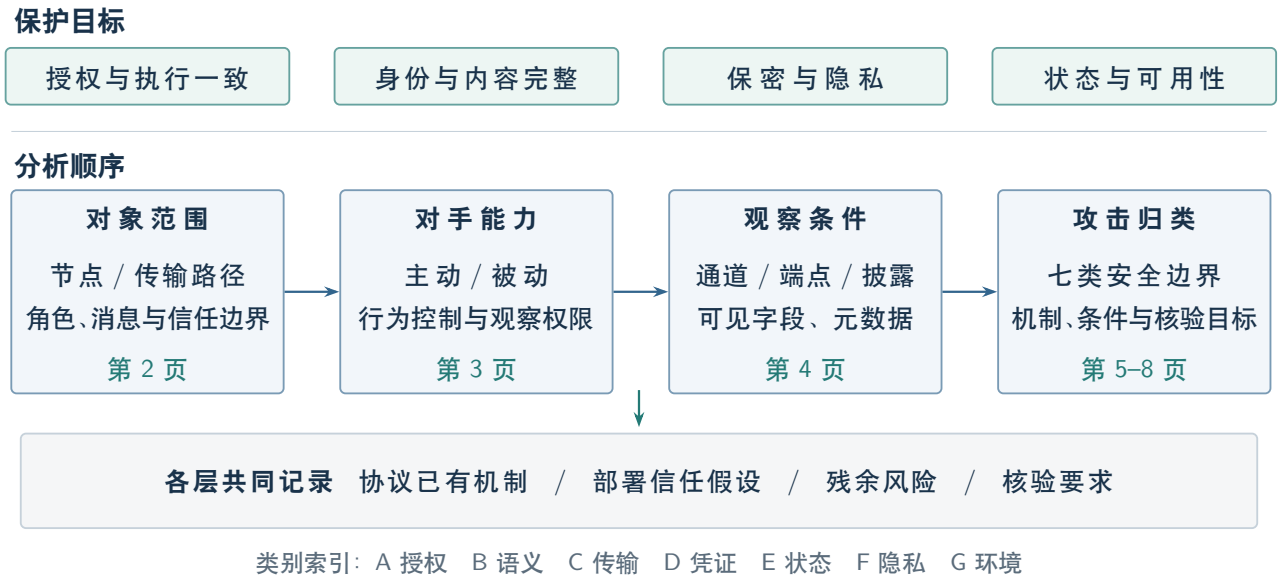


图 1 从保护目标到分类汇总的分析结构。对象、能力与观察条件共同决定风险，不能仅凭某一项标签判断攻击是否成立。

协议基线 AP2 已规定签名授权、密钥绑定、交易哈希绑定、选择性披露及相应核验规则。其作用是将用户要求锁定到 AP2 授权凭证中，并在交易执行时逐项核验；具体保护强度取决于约束表达、密码实现和核验执行是否正确。[P1–P3]

研究边界 本文采用用户不在场的授权流程作为分析基线，并纳入模型、工具和部署依赖。图中的角色可由不同实体承担，也可合并部署；合并部署不会消除其逻辑职责与信任边界。

结论性质 所列内容是有条件的威胁分析，不是已复现漏洞清单。分类用于检查主要安全边界；风险覆盖程度仍取决于实际部署、权限配置、消息类型与对手组合。

依据：AP2 规范、授权模型与安全考虑 [P1–P3]。参考文献见第 9 页。

02 对象范围

先划定节点，再展开每一次传输

node 是处理、保存或决定信息的信任主体；transpath 是两个主体之间的一次有向逻辑传递。同一消息经过代理、网关或其他可读取内容的中间主体时，应继续拆分节点与路径。

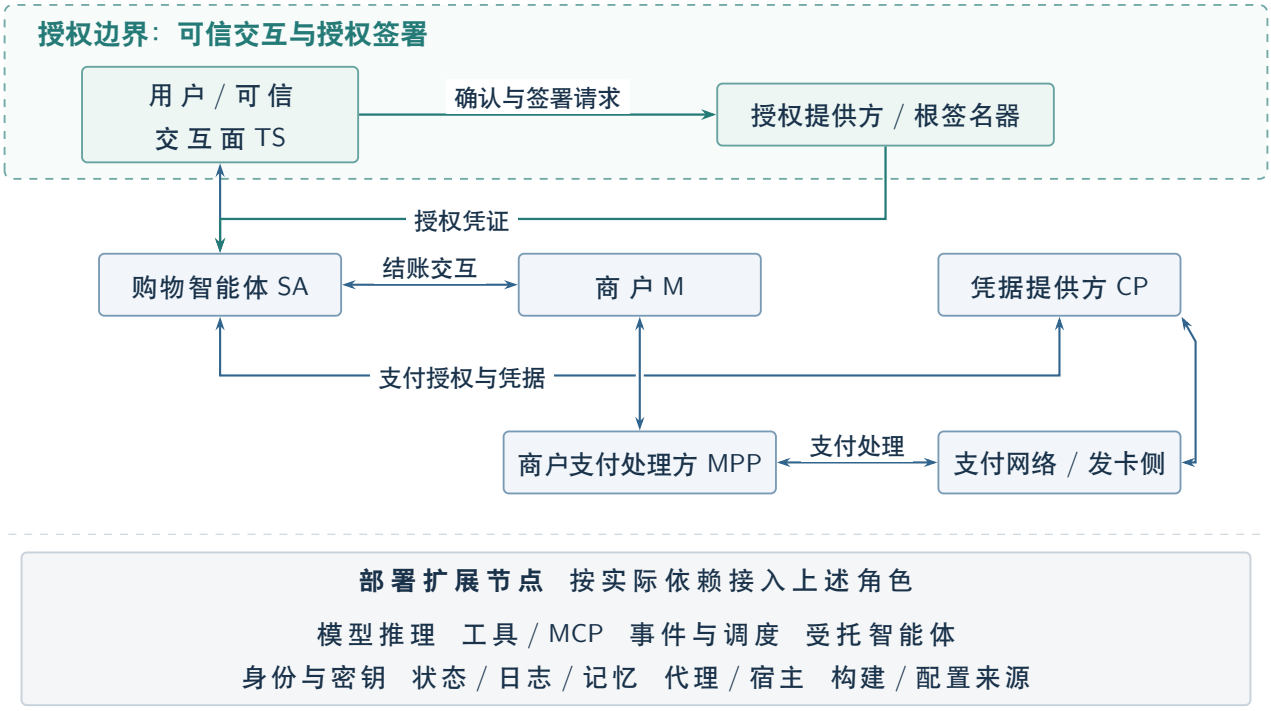


图 2 AP2 角色关系与扩展对象。双向线仅表示交互关系，具体分析时必须拆为不同方向的 transpath；本图不是完整报文时序。授权区域采用可信授权提供方模型，支付网络分支按支付轨道确定。

有向对象模型 将部署记为有向多重图 $G = (V, E)$，其中 V 为节点集合，$e = (u, v, m, c) \in E$ 表示从节点 u 到节点 v、经通道 c 传递消息类型 m。请求、响应、回执、通知与状态读写分别建模；同一对节点之间可存在多条不同的逻辑路径。

范围划分 业务层覆盖授权、结账、凭据交付、支付与回执；智能体层覆盖推理、工具、事件和委派；基础设施层覆盖身份、密钥、存储、网关、宿主和构建来源。节点内部若存在独立权限或密钥边界，也应继续拆分。

记录要求 每条路径至少记录发送方、接收方、消息内容、保护方式与验证责任；每个节点至少记录持有数据、可用密钥、可调用权限与依赖状态。图形的角色分组用于阅读，安全检查仍逐节点、逐方向、逐消息类型进行。

依据：AP2 角色、流程、授权及实现考虑 [P1, P2, P4, P5]；部署扩展为本文的分析范围。参考文献见第 9 页。

03　对手能力

对象位置与主动、被动是两条独立轴

被动对手保持所建模协议行为，利用可获得的信息进行观察、保留或关联；主动对手能够偏离协议行为。对手控制一个节点，并不自动意味着控制其所有相邻节点或所有传输通道。

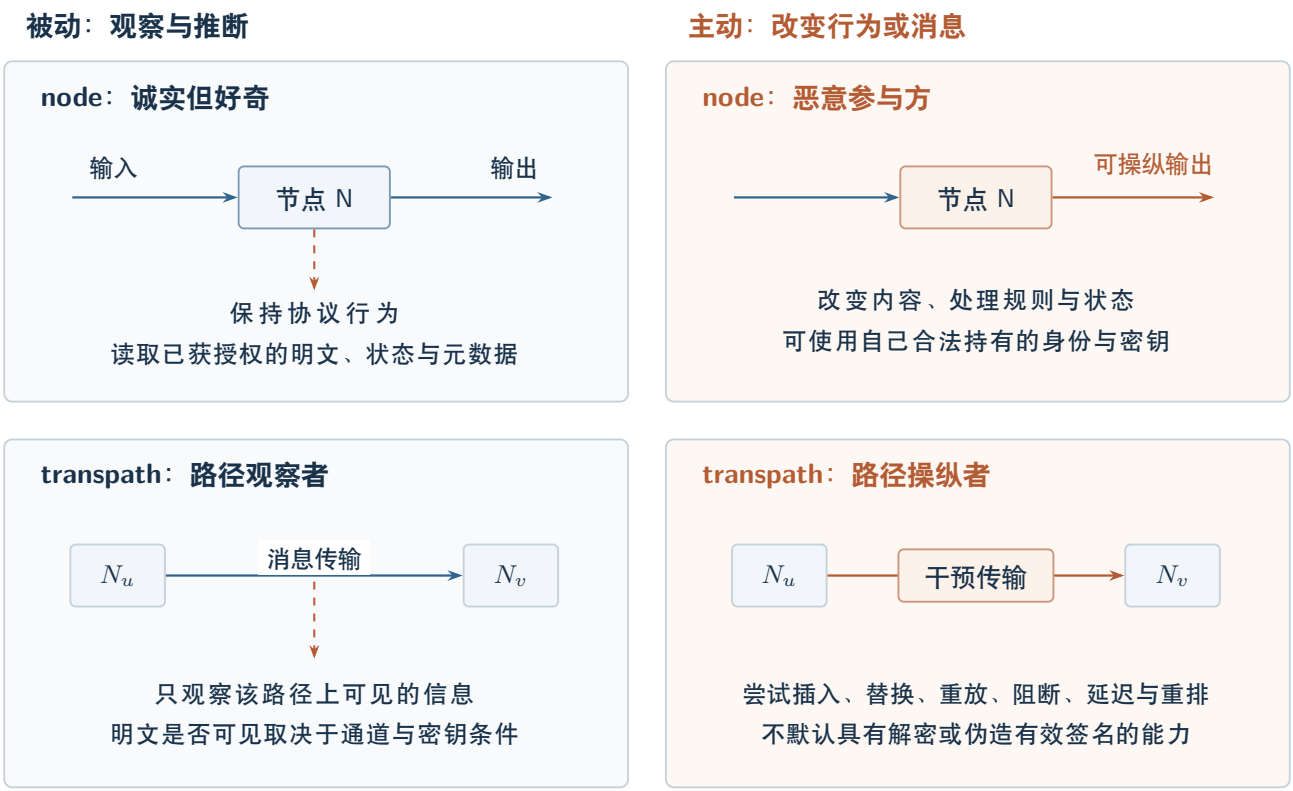


图 3　四类基础对手能力。主动性描述能否改变系统行为，观察条件描述能够知道什么；两者必须分别说明。

能力不等于攻击成功　主动路径对手可以干预传递，但正确的认证、加密与完整性保护会使部分篡改被拒绝。恶意节点则可能在保持签名有效的同时生成不真实或具有误导性的内容，因此不能以验签通过替代内容与授权核验。

组合与串谋　多个受控节点、多个受控路径可以组成联合对手。联合能力包括各方获得的数据、可执行权限以及相互配合的机会；不能仅将单点结论直接外推为多点安全结论。

必要信任假设　每项结论应指出仍诚实的授权来源、密钥保护组件、核验器和执行端。若保护某项属性所必需的组件全部被控制，就不能继续主张该属性由原有机制保证。

依据：AP2 安全考虑与授权模型 [P2, P3]；TLS 和 JWT 安全边界 [S1, S3]。参考文献见第 9 页。

04　观察条件与 C 类风险

先确定可见信息，再判断泄露与篡改

观察能力取决于加密终点、字段披露、密钥权限和本地状态。下列四种条件描述不同观察位置，不构成简单的强弱排序；同一部署可同时存在多种条件。



图 4　观察位置决定信息可见性。密文传输、节点解密与端点持有数据是不同的安全条件，不能合并成笼统的“路径泄露”。

C：传输与会话　主动威胁包括身份冒用、通道降级、消息干预与会话混淆；其可行性受认证和完整性校验限制。连接层的完整性保护不替代应用层的授权检查、请求新鲜性、业务去重与状态一致性。丢弃、延迟和流量分析也不会仅因内容加密而消失。[S1]

三种机制的边界　加密限制未授权读取；签名验证来源和内容完整性；选择性披露减少交给接收方的字段。三者不能相互替代，也不能自动阻止接收方保存、串谋或关联已经获得的信息。[P3, S1, S2]

依据：AP2 安全与隐私考虑 [P3]；TLS 1.3、SD-JWT 和 JWT 安全建议 [S1–S3]。参考文献见第 9 页。

05 A / B 类风险

授权语义与智能体行为分别受约束

签名保护已表达的内容，不能证明内容忠实于用户意图。授权形成过程需要保证来源、表达与确认的一致性；运行过程需要防止外部内容获得本不应拥有的指令权限。

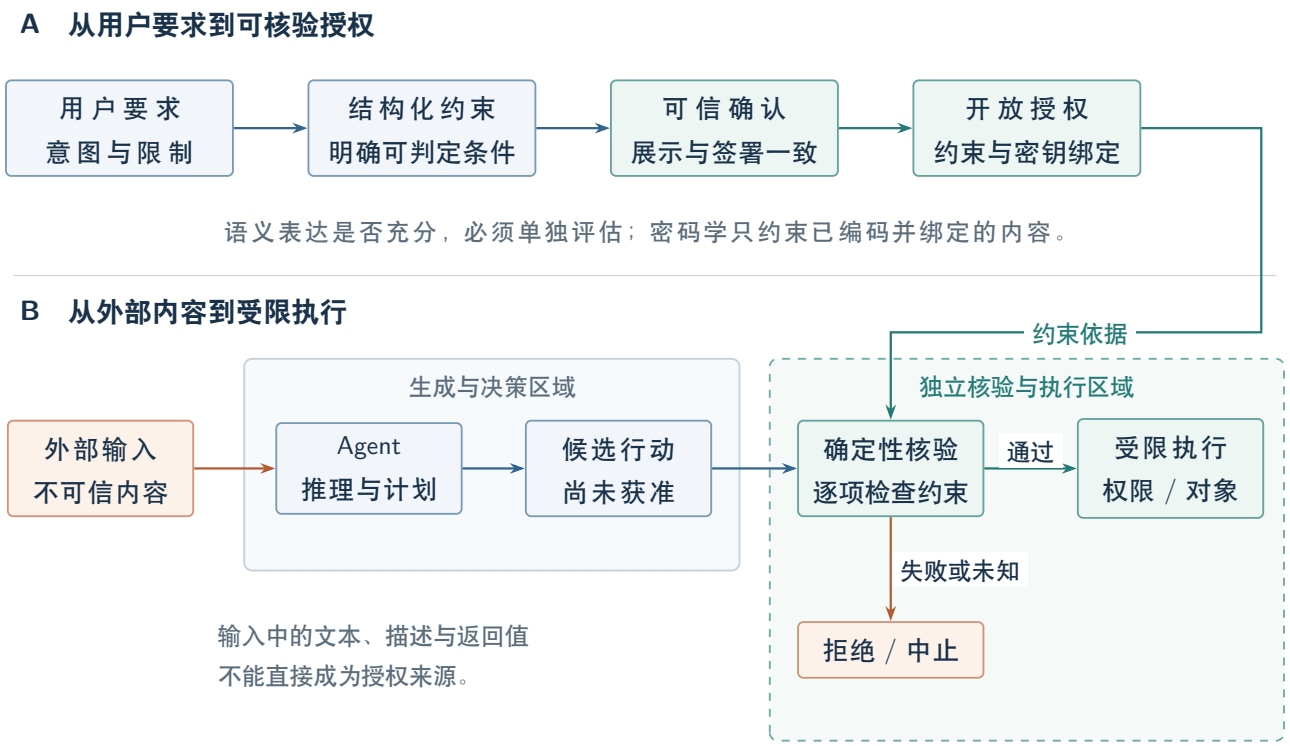


图 5 授权形成与行为执行的两道边界。核验器只能强制实施已明确定义的规则；未被形式化的语义要求仍需独立处理。图中的执行隔离是部署要求，不由协议格式自动产生。

A：授权来源与意图一致性 风险包括授权内容替换、确认界面与签署内容不一致、身份或授权来源混淆，以及约束遗漏造成的权限扩大。被动观察还可能暴露用户偏好、授权范围与身份关联。需核对“要求、展示、签署、执行”的一致性，并保护根签名器。[P1, P2]

B：外部内容与智能体语义 恶意内容源、模型、工具或被污染的记忆可影响智能体对指令、数据和权限的判断，使其生成越权计划或不当调用。即使输入来自已认证主体，也不能因此将其视为用户授权。提示注入检测不能作为唯一执行屏障。[P3, S4]

核验要求 可信交互面须由非智能体逻辑实现，确认内容与签名请求应保持绑定；开放授权中的既有值不能被关闭授权改写；约束必须由确定性代码核验，未知约束按失败处理。核验器本身若被控制，其保护结论不再成立。[P1, P2]

依据：AP2 规范、授权与安全考虑 [P1–P3]；OWASP 提示注入说明 [S4]。参考文献见第 9 页。

06　D / E 类风险

凭证关联正确，还需要交易状态正确

密码学绑定回答“谁授权了哪些内容”；状态控制回答“该授权当前是否仍可使用”。前者不自动保证跨请求、跨节点和跨时间的一致执行。

D　授权链与交易关联

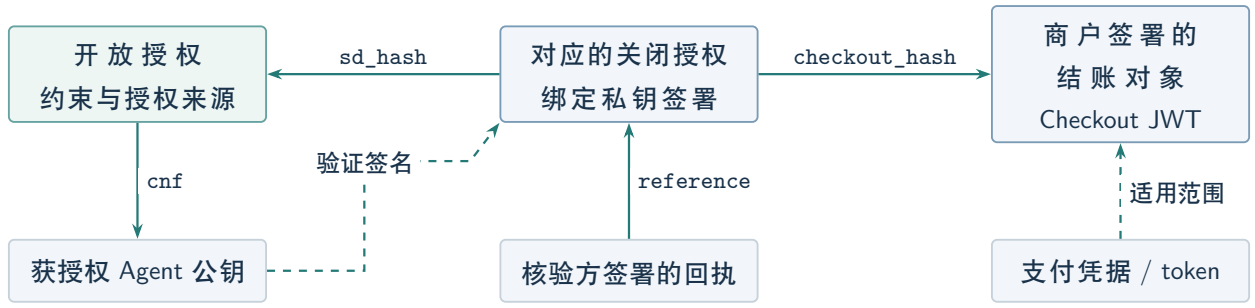


图 6　凭证关联的抽象结构。结账授权与支付授权分别建链；支付授权经 `transaction_id` 中的结账哈希关联交易，回执关联对应授权。支付凭据的具体范围绑定取决于支付方式。

E　请求、执行与结果的状态约束

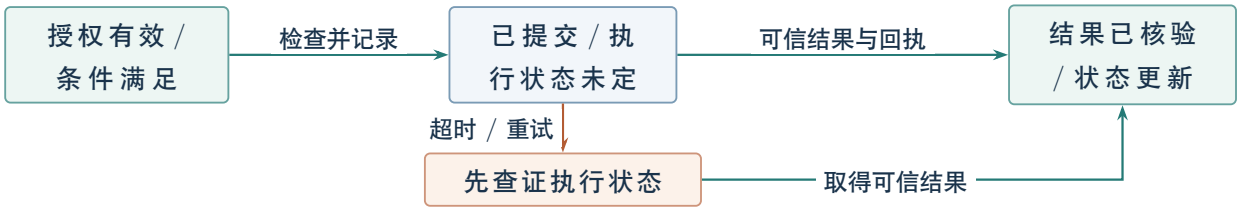


图 7　状态核验的分析模型，不是 AP2 统一规定的状态机。并发控制、去重范围、撤销与异常恢复需在具体部署中明确。

D：凭证与密码学绑定　风险包括链拼接、上下文替换、算法或类型混淆、解析不一致、密钥泄露、随机性不足与凭据滥用。应验证密钥来源、签名算法、凭证类型、关联哈希、约束及适用范围；哈希计算必须使用一致的表示，隐私相关摘要需满足相应熵要求。[P2, P3, P5, S2, S3]

E：状态与生命周期　重放、并发、状态回滚、回执伪造或延迟，可能使同一授权产生重叠执行。AP2 对重叠关闭授权及回执完整性已有要求；去重、原子更新、撤销、过期与后续交易状态仍需落实到具体实现。开放授权不能仅凭名称被视为一次性令牌。[P1, P3]

核验时应分别统计凭据重复签发、并存有效凭据与实际支付效果，不能将三者直接等同。结果不确定时应进入查证或中止流程，不能自动扩大授权或跳过校验。

依据：AP2 规范、授权、安全和实现考虑 [P1–P3, P5]；SD-JWT 与 JWT 建议 [S2, S3]。参考文献见第 9 页。

07　F / G 类风险

隐私与执行环境决定协议之外的暴露面

单个主体获得必要信息，不意味着多个主体合并信息后仍只知道必要内容。同样，凭证格式正确，也不意味着处理凭证的模型、工具、密钥服务与宿主环境可信。

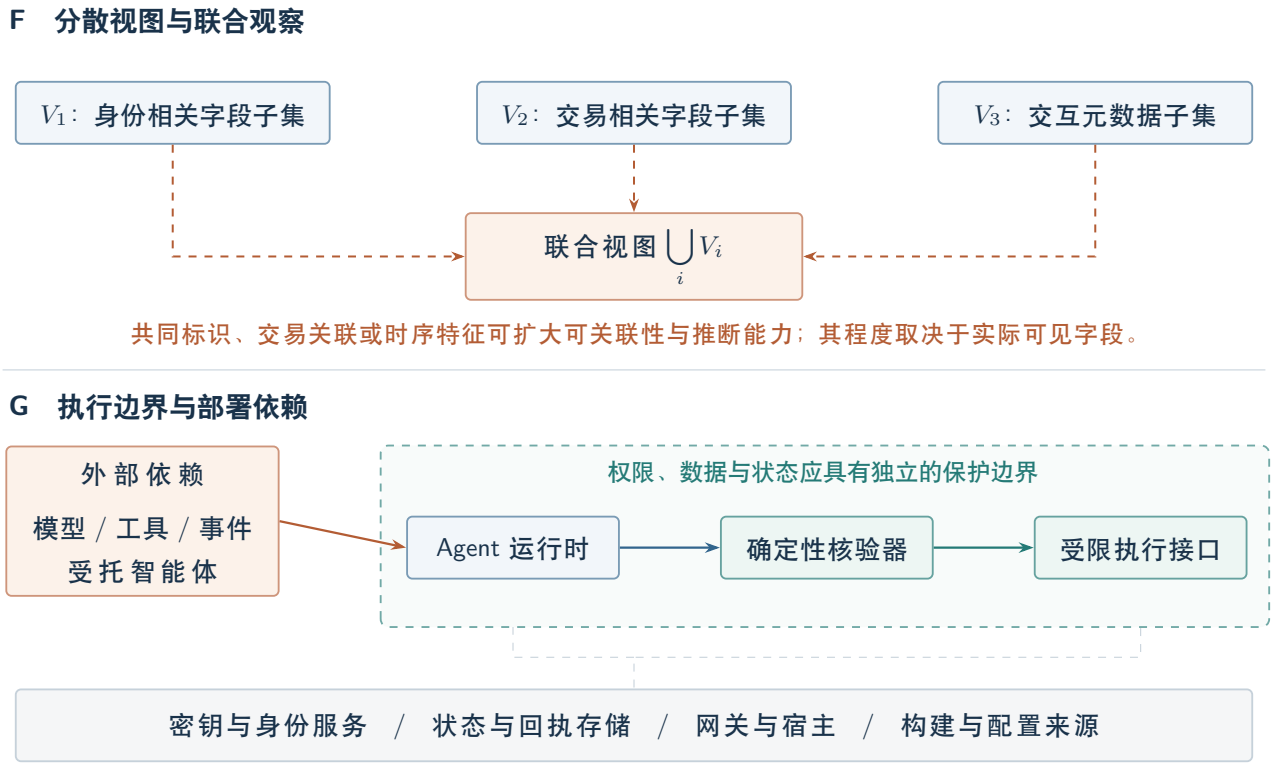


图 8　隐私关联与执行依赖的两层分析。上半图表示一般的数据视图，不规定各角色必须接收哪些字段；下半图表示待落实的隔离要求，不假定基础设施天然可信。

F：隐私与跨方关联　被动风险包括偏好推断、身份与交易关联、长期画像及跨会话追踪；主动风险还包括诱导额外披露与操纵查询以收集信息。需限定字段、用途、留存与共享边界，并按联合对手评估视图。SD-JWT 的选择性披露不等同于一般意义上的不可关联性。[P3, S2]

G：工具、运行时与基础设施　恶意工具、被替换的依赖、过宽权限及失陷宿主可能绕过上层授权边界；资源耗尽还可能诱发不安全降级。应控制调用身份、目的端与权限范围，保证委派不扩大上游授权，隔离密钥和敏感状态，核对依赖来源，并限制调用和重试资源。[P2, P5, S5]

共同边界　密码学机制不能阻止已被攻陷的端点在其可读范围内泄露信息，也不能代替执行端履行授权检查。故障恢复、权限收缩和证据保存，应保持原有约束而不引入自动绕过。

依据：AP2 授权、隐私与实现考虑 [P2, P3, P5]；SD-JWT 和 MCP 安全建议 [S2, S5]。参考文献见第 9 页。

08 分类总表

按安全边界归纳，按对象与条件核验

表 1 汇总前文的七类风险。类别是本文的分析分组，并非 AP2 官方分类；同一攻击链可跨越多个类别。**主动列描述可能的干预机制，被动列描述给定观察条件下的信息风险，均不表示必然成功。**

类别与主要对象	主动攻击机制	被动观察风险	关键保护与验证
A 授权与意图 TS、签名器、Agent 授权交互路径	授权替换；确认欺骗；身份混淆；约束遗漏与越权	偏好、意图与授权范围暴露；身份关联	核对要求、展示、签署与执行的一致性；保护根签名器；明确约束表达边界
B 智能体语义 内容、模型、工具记忆及输入路径	提示注入；工具返回误导；记忆污染；指令与数据混淆	上下文、计划和记忆中的任务信息暴露	输入不得授予权限；候选行动经独立确定性核验；未知约束失败
C 传输与会话 传输路径、代理连接与会话	身份冒用与降级；插入、重放、阻断、延迟与重排	未保护明文；残留端点、长度与时序信息	认证与通道保护；明确加密终点；补足应用层新鲜性和去重
D 凭证与绑定 签发方、核验方凭证、密钥与回执	链拼接与上下文替换；算法、类型和解析混淆；凭据滥用	披露字段、低熵摘要与凭证标识造成泄露或关联	核对签名、链、类型、哈希、约束与范围；统一编码；保护密钥和随机性
E 状态与生命周期 Agent、CP、MPP 状态与结果路径	重放与并发重叠；回滚；回执伪造或压制；生命周期绕过	历史状态、时间与回执记录形成长期关联	原子更新与去重；核验回执；查证未定结果；落实过期、撤销与后续状态
F 隐私与关联 持有数据的节点多路径联合观察	额外披露诱导；查询操纵；跨方收集与串谋	联合视图关联；画像与偏好推断；跨会话追踪	最小披露、用途和留存限制；评估联合视图；不预设不可关联性
G 执行与基础设施 工具与部署依赖调用与配置路径	权限滥用；依赖与事件投毒；资源耗尽；降级绕过	宿主、工具和日志中的内容及访问行为暴露	最小权限与隔离；核对目的端和依赖来源；限制资源；故障不放宽授权

表 1 七类风险的总览。对象、主动 / 被动能力与观察条件共同限定每一项分析结论。

使用顺序 先确定具体 node 或 transpath，再标明主动 / 被动、可见信息、控制权限和仍可信的组件，最后对应上述类别。分类索引不能替代攻击前提、受损属性与成功判据。

总表综合前文 [P1–P5, S1–S5]。它用于组织威胁分析，不构成漏洞穷尽证明，也不表示某一部署已存在全部所列问题。

09 依据与适用范围

协议事实、分析推导与部署要求分别表述

版本范围 协议事实以本项目仓库的 v0.2 文档为准。后续协议或实现变更需要重新核对角色、凭证、字段及核验规则。

证据层次 协议规范说明已有机制与规定责任；标准和安全指南补充通用的密码、传输与智能体风险。对象图、观察条件 O1–O4、类别 A–G 以及状态核验图是本文的分析组织方式。隔离、状态原子性、数据治理等要求需由部署实现，不能从协议格式直接推断其已满足。

AP2 协议与实现资料

[P1] AP2 Specification。角色、可信交互面、用户不在场流程与各方验证责任。

[P2] Agent Authorization。授权来源、开放 / 关闭授权、密钥绑定、约束核验与签署回执。

[P3] Security and Privacy Considerations。交易绑定、恶意智能体、凭据保护、重叠授权与选择性披露。

[P4] AP2 Flows。授权、结账、凭据发放、支付及回执的参与关系。

[P5] Implementation Considerations。实现职责、签名与哈希表示、状态管理及部署相关考虑。

通用标准与安全指南

[S1] IETF，RFC 8446: The Transport Layer Security (TLS) Protocol Version 1.3，2018。传输保护、流量分析边界与重放相关考虑。

[S2] IETF，RFC 9901: Selective Disclosure for JSON Web Tokens，2025。选择性披露、密钥绑定、摘要盐值及可关联性边界。

[S3] IETF，RFC 8725: JSON Web Token Best Current Practices，2020。算法、签发方、受众、类型与验证规则。

[S4] OWASP，LLM01: Prompt Injection。提示注入、权限限制与防护边界；访问日期：2026-11-01。

[S5] Model Context Protocol，Security Best Practices，2025-11-25 文档路径。工具授权、令牌使用、会话与运行环境风险；访问日期：2026-11-01。

验证边界：实际安全结论需补充部署拓扑、实现检查及具有明确成功判据的验证证据。本文未将概念性威胁机制表述为已确认漏洞或已测得的攻击效果。